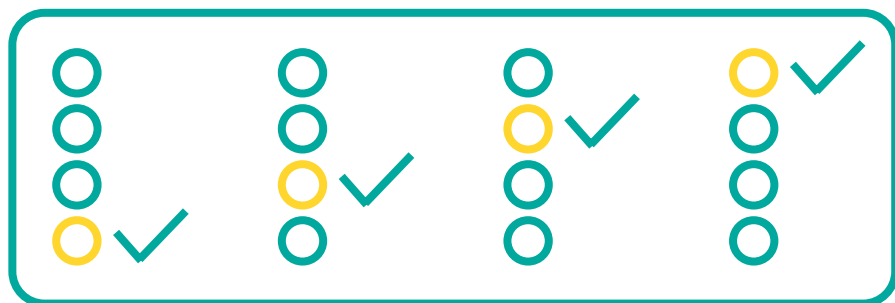


GABARITO DAS AUTOATIVIDADES



SEGURANÇA EM TECNOLOGIA DA INFORMAÇÃO

Prof. Rodrigo Ramos Nogueira
Prof. Rogério Bodemüller Junior

2020

UNIDADE 1**TÓPICO 1**

Utilize o cenário a seguir descrito para responder as questões desta autoatividade.

(ENADE 2008 - Adaptado) A Secretaria de Saúde de determinado município está executando um projeto de automação do seu sistema de atendimento médico e laboratorial, atualmente manual. O objetivo do projeto é melhorar a satisfação dos usuários com relação aos serviços prestados pela Secretaria. O sistema automatizado deve contemplar os seguintes processos: marcação de consulta, manutenção de prontuário do paciente, além do pedido e do registro de resultados de exame laboratorial. A Secretaria possui vários postos de saúde e cada um deles atende a um ou mais bairros do município. As consultas a cada paciente são realizadas no posto de saúde mais próximo de onde ele reside. Os exames laboratoriais são realizados por laboratórios terceirizados e conveniados. A solução proposta pela equipe de desenvolvimento e implantação da automação contempla, entre outros, os seguintes aspectos:

- sistema computacional do tipo cliente-servidor na web, em que cada usuário cadastrado utiliza login e senha para fazer uso do sistema;
- uma aplicação, compartilhada por médicos e laboratórios, gerência o pedido e o registro de resultados dos exames. Durante uma consulta o próprio médico registra o pedido de exames no sistema;
- uma aplicação, compartilhada por médicos e pacientes, permite que ambos tenham acesso aos resultados dos exames laboratoriais;
- uma aplicação, compartilhada por médicos e pacientes, que automatiza o prontuário dos pacientes, em que os registros em prontuário, efetuados por cada médico para cada paciente, estão disponíveis apenas para o paciente e o médico específicos. Além disso, cada médico pode fazer registros privados no prontuário do paciente, apenas visíveis por ele;

- uma aplicação, compartilhada por pacientes e atendentes de postos de saúde, que permite a marcação de consultas por pacientes e(ou) por atendentes. Esses atendentes atendem o paciente no balcão ou por telefone.

1 (TRE-CE 2011 – Adaptado) Um ponto muito importante e que deve ser levado em consideração nesta solução, mesmo porque ela irá tratar com dados privados e extremamente sensíveis, é a segurança da informação. Sobre este tema, avalie as afirmações a seguir:

- I- É obtida a partir da implementação de um conjunto de controles adequados, incluindo políticas, processos, procedimentos, estruturas organizacionais e funções de software e hardware.
- II- Os controles de segurança precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, onde necessário, para garantir que os objetivos do negócio e de segurança da organização sejam atendidos. Convém que isto seja feito em conjunto com outros processos de gestão do negócio.
- III- É importante para os negócios do setor público para proteger as infraestruturas críticas, mas não no setor privado. A função da segurança da informação é viabilizar os negócios como o governo eletrônico (e-Gov) e evitar ou reduzir os riscos relevantes.

Assinale a alternativa CORRETA:

- a) **(X) As afirmativas I e II estão corretas.**
- b) () As afirmativas I e III estão corretas.
- c) () As afirmativas II e III estão corretas.
- d) () A afirmativa I está correta.

2 (SEFAZ-RS 2014 – Adaptado) Na segurança da informação, vários componentes estão envolvidos na gestão de riscos, tais como os agentes, as ameaças e os ataques. A fragilidade de um ativo, como os servidores que hospedam o sistema da Secretaria da Saúde, que pode ser explorada por uma ou mais ameaças, é chamada de:

- a) () Risco.
- b) () Incidente.
- c) () Ameaça.
- d) (X) Vulnerabilidade.

3 (SEFAZ-RS 2014 – Adaptado) Vários conceitos permeiam na análise e gestão de riscos em segurança da informação, tais como ameaças, vulnerabilidades, ataques, medidas protetivas, entre outros. No antigo sistema da Secretaria da Saúde, existia a fragilidade do armazenamento dos registros em papel que poderiam, por exemplo, serem queimados por um incêndio iniciado por um curto-circuito. A fragilidade deste ativo, que pode ser explorada por uma ou mais ameaças, é chamada de:

- a) () Risco.
- b) () Incidente de segurança da informação.
- c) () Desastre.
- d) (X) Vulnerabilidade.

4 (ENADE 2011 – Adaptado) Em um determinado momento, o servidor que hospeda o sistema da Secretaria de Saúde recebe uma quantidade de requisições de operações, vindas de números IPs distintos, muito acima das condições operacionais previstas para os seus recursos e “trava”, isto é, os seus serviços são interrompidos. Muitas empresas e entidades governamentais sofrem esse tipo de ataque hacker. Para realizá-lo, um atacante precisa distribuir um código, em vários computadores, normalmente sem o consentimento dos destinatários, que se tornam seus “zumbis”. Em um momento, o atacante ativa os “zumbis” que fazem muitos acessos a um determinado alvo, acabando por esgotar seus recursos e derrubando o sistema de informações. A respeito do ataque que o sistema da Secretaria de Saúde foi alvo, analise as afirmações a seguir:

- I- É um ataque de negação de serviço (*Denial Of Service*).
- II- É um ataque que ameaça o atributo da disponibilidade do sistema.
- III- É um ataque em que os hackers roubam as senhas dos usuários, para poder enviar requisições.
- IV- É um ataque não detectável por sistemas de antivírus.

Assinale a alternativa CORRETA:

- a) **(X) As afirmativas I e II estão corretas.**
- b) () As afirmativas I e IV estão corretas.
- c) () As afirmativas II e III estão corretas.
- d) () As afirmativas III e IV estão corretas.

5 (ENADE 2008 – Adaptado) Considerando que entre os principais benefícios deste projeto de melhoria de sistema de informação destacam-se o aumento da: eficiência (ato de fazer as coisas da maneira certa); eficácia (ato de fazer a coisa certa); integridade; e disponibilidade, avalie as afirmações a seguir:

- I- A falta de energia elétrica, por exemplo, poderá levar ao não funcionamento do servidor ou das máquinas clientes web, fazendo com que as informações sobre prontuários, pacientes, consultas e exames fiquem inacessíveis.
- II- Falhas de conectividade à internet poderão levar o sistema à indisponibilidade, e impedir que o médico acesse as informações do paciente, que os atendentes marquem consultas, que os laboratórios recebam e processem pedidos de exame etc.
- III- Quebra de equipamentos de armazenamento, como discos rígidos e outras mídias, poderão levar a perda de informações sobre pacientes, médicos, exames, laboratórios etc.
- IV- Incêndios em postos de saúde poderão prejudicar a restauração do funcionamento destes, pois todos os dados dos pacientes e médicos serão perdidos caso os computadores deste posto de saúde também sofram com o incêndio.

Assinale a alternativa que descreve riscos de segurança da informação que aumentam quando se substitui o sistema atual pelo sistema proposto, e que são relativos à interação entre pacientes e os serviços da referida secretaria de saúde.

- a) () As afirmativas I e III estão corretas.
- b) () As afirmativas II e IV estão corretas.
- c) () As afirmativas I, II e IV estão corretas.
- d) **(X) As afirmativas I, II e III estão corretas.**

6 (ENADE 2017 – Adaptado) A Secretaria de Saúde sofreu um novo ataque hacker e seus sistemas foram comprometidos. Depois de alguns dias, a equipe de Tecnologia da Informação (TI) da secretaria conseguiu reestabelecer os sistemas, tendo a gestora de TI apresentado um plano com o intuito de criar um setor especializado em segurança da informação para evitar novos ataques. Após a análise dos riscos e benefícios do plano, foi aprovada a implantação do referido setor de segurança da informação. A partir desta especificação do cenário, avalie as asserções a seguir e a relação proposta entre elas.

I- A implantação de um setor de segurança da informação está associada ao desenvolvimento de uma política de segurança da informação, que é um conjunto de normas, métodos e procedimentos utilizados para a manutenção da segurança da informação, devendo ser formalizada e divulgada a todos os usuários.

PORQUE

II- É interessante verificar a possibilidade de implantação de um sistema que auxilie na preservação da confidencialidade, da integridade e da disponibilidade da informação, por meio da aplicação de um processo de gestão de riscos, fornecendo a confiança de que os riscos são adequadamente gerenciados, sendo importante que este sistema esteja integrado aos processos da organização e a sua estrutura global.

A respeito dessas asserções, assinale a opção CORRETA:

- a) () As asserções I e II são proposições verdadeiras, e a II é uma justificativa correta da I.
- b) (X) **As asserções I e II são proposições verdadeiras, mas a II não é uma justificativa correta da I.**
- c) () A asserção I é uma proposição verdadeira, e a II é uma proposição falsa.
- d) () A asserção I é uma proposição falsa, e a II é uma proposição verdadeira.

TÓPICO 2

Utilize o cenário do sistema para a Secretaria da Saúde, já apresentado na autoatividade anterior, para responder às questões a seguir.

1 (ENADE 2008 – Adaptado) Para elevar o nível de segurança do sistema da Secretaria da Saúde foi estabelecido que o acesso à interface web do servidor utilizará o protocolo HTTPS, onde uma sessão SSL é estabelecida entre browser do usuário e o servidor. Para tanto, usam-se mecanismos baseados em criptografia simétrica e assimétrica para prover serviços de segurança. Em comparação ao acesso HTTP, sem SSL, que serviços de segurança são providos para o usuário?

- a) () Autenticação do servidor e controle de acesso do cliente.
- b) () Autenticação do cliente e controle da velocidade de transmissão.
- c) () Autenticação da rede e proteção contra vírus.
- d) (X) Autenticação do servidor e confidencialidade das transmissões.

2 (ENADE 2011 – Adaptado) Para garantir o sigilo médico, foi estabelecido que a solução proposta deverá possibilitar uma forma de comunicação segura entre o médico e o paciente. Existe uma preocupação com a possibilidade de interceptação e alteração das mensagens durante as suas transmissões. Para reduzir a possibilidade de que um atacante tenha acesso ao conteúdo da mensagem, foi adotado um procedimento de criptografia de chave pública e assinatura digital. Considerando a utilização dessas tecnologias para a codificação da mensagem que será enviada do paciente (remetente) para o médico (destinatário), avalie as afirmações que se seguem:

- I- Para o procedimento de cifragem da mensagem, é utilizada a chave pública do médico.
- II- Para o procedimento de assinatura digital da mensagem, é utilizada a chave pública do médico.
- III- Para o procedimento de decifragem da mensagem, é utilizada a chave privada do paciente.
- IV- Para o procedimento de verificação da assinatura digital da mensagem, é utilizada a chave pública do paciente.

Assinale a alternativa CORRETA:

- a) () As afirmativas I e II estão corretas.
- b) (X) As afirmativas I e IV estão corretas.
- c) () As afirmativas II e III estão corretas.
- d) () As afirmativas III e IV estão corretas.

3 (ENADE 2009 – Adaptado) Pesquisadores da área de tecnologia da informação advertem para o fato de que sistemas de informação computadorizados são mais vulneráveis a destruição, erros, mau uso e crime do que os sistemas manuais, em que a informação é geralmente guardada sob a forma de registros em papel. Analise as afirmativas a seguir, como formas possíveis de agregar segurança à solução que a Secretaria da Saúde está adotando.

- I- Guardar todos os seus bancos de dados e seus respectivos backups utilizando as senhas padrões do sistema, que serão sempre seguras.
- II- Instalar sistemas de segurança de acesso aos arquivos e sistemas, tais como log in e senhas.
- III- Instalar sistemas de proteção contra vírus e hackers para poder se proteger contra-ataques internos e externos.
- IV- Desativar o sistema de criptografia de dados para poder acelerar a velocidade de transmissão dos dados.

Assinale a alternativa CORRETA:

- a) () As afirmativas I e II estão corretas.
- b) () As afirmativas I e IV estão corretas.
- c) (X) As afirmativas II e III estão corretas.
- d) () As afirmativas III e IV estão corretas.

4 (POSCOMP 2012 – Adaptado) Para aumentar a segurança no acesso às contas dos médicos no sistema da Secretaria de Saúde, solicitou-se que, além da biometria com impressão digital, fosse cadastrada uma senha composta por uma sequência de seis letras minúsculas. Nessas condições, e considerando o alfabeto com 26 letras, assinale a alternativa que apresenta, corretamente, a quantidade de possíveis senhas a serem formadas.

- a) () 81.092.624
- b) () 19.770.609.664
- c) () 165.765.600
- d) (X) 308.915.776

5 (LIQUIGAS 2012 – Adaptado) Os sistemas criptográficos contemporâneos se valem do poder de processamento dos computadores para criar algoritmos difíceis de quebrar, como os selecionados para a solução adotada pela Secretaria da Saúde. Essa mesma capacidade de processamento é uma das forças da criptoanálise. Nesse contexto, um dos conceitos (princípio de Kerckhoffs) que prevalecem para certificar ou homologar algoritmos criptográficos é que eles devem ser tão bem construídos que sua resistência a ataques de criptoanálise não deve residir no sigilo do algoritmo, mas, unicamente, no segredo da(o):

- a) (X) Chave.
- b) () Assinatura do remetente.
- c) () Identidade do destinatário.
- d) () Canal de transmissão.

6 (TCE-ES 2013 – Adaptado) Segurança se refere a algo que deve sempre estar em análise e evolução. Com o aumento do poder computacional, barreiras que antes tornavam o sistema seguro, agora não o fazem mais. Com referência ao controle de ativos de informação da Secretaria da Saúde, julgue os itens que se seguem e assinale a alternativa CORRETA:

- a) () O uso de biometria como mecanismo de autenticação do usuário no acesso aos sistemas de informação é cada dia mais utilizado e tem a vantagem de rápida implantação com baixo custo, possibilitando a instalação em todos os postos de saúde desta cidade.
- b) (X) Devido aos constantes ataques aos usuários de sistemas bancários, é cada vez mais comum a adoção de mecanismos de autenticação com base em segundo fator de autenticação. Seguindo este exemplo, poderia ser utilizada a senha e biometria para o acesso ao sistema da Secretaria de Saúde.

- c) () Para a segurança da informação, todas as informações são igualmente importantes. Deve garantir que, tanto as informações de salário dos funcionários, quanto os telefones de contato dos laboratórios, devem ser protegidas com o mesmo rigor.
- d) () Um dos controles de acesso aos sistemas de informação mais utilizados é a identificação pelo uso de log in do tipo usuário e senha. A vantagem nesse tipo de controle de acesso relaciona-se ao seu baixo custo e à possibilidade de se garantir o não repúdio no acesso, garantindo que o médico, paciente ou laboratório é quem ele diz ser.

7 (DATAPREV 2014 – Adaptado) Um tema muito recorrente, quando se pensa em segurança da informação, é a análise de riscos, que tem a função de indicar se um risco pode ou não ser aceito pela organização. Os riscos podem ser classificados como físicos, ambientais e riscos lógicos. Assinale a alternativa que contém o que pode ser considerado um risco lógico para este sistema da Secretaria da Saúde.

- a) () Cabo desconectado durante limpeza.
- b) () Vandalismo que gerou equipamentos destruídos.
- c) () Parada dos servidores por causa de um vazamento de água dentro do datacenter.
- d) (X) **Ataque hacker.**



TÓPICO 3

Assim como feito nas autoatividades anteriores, utilize o cenário do sistema da Secretaria de Saúde para responder às questões a seguir, considerando as instalações onde os servidores deste sistema estão localizados.

- 1 (CESPE 2013 – Adaptado)** Considere que o rompimento de um cabo tenha interrompido a comunicação entre uma das clínicas médicas e o servidor que provê o acesso ao sistema da Secretaria

da Saúde, que utiliza cabeamento estruturado. Com base nisto, assinale a opção em que é apresentada uma área de segurança da informação segundo a qual os controles implementados podem prevenir esse tipo de incidente.

a) (X) **Segurança física.**

b) () Controle de acesso à rede.

c) () Controle de acesso à aplicação e informação.

d) () Segurança lógica.

2 (AGU 2014 – Adaptado) Segundo a Norma ISO/IEC 27002:2005, utilizada na preparação do prédio que hospeda o servidor, a segurança física e do ambiente tem como objetivo prevenir o acesso físico não autorizado, danos e interferências com as instalações e informações. Considerando o que foi estudado até aqui, assinale a alternativa CORRETA acerca do perímetro de segurança física a ser seguido.

a) () Devem-se construir barreiras lógicas e ambientais, onde aplicável, para impedir o acesso físico não autorizado e a contaminação do meio ambiente.

b) () As instalações de processamento da informação gerenciadas pela organização podem ficar fisicamente juntas daquelas que são gerenciadas por terceiros.

c) (X) **A localização e a capacidade de resistência de cada perímetro dependem dos requisitos de segurança dos ativos existentes no interior do perímetro, e dos resultados da análise/avaliação de riscos.**

d) () Os visitantes não precisam ser supervisionados, pois o registro da data e a hora da entrada e saída podem ser utilizados como o registro de acesso.

3 (TRE-MS 2012 – Adaptado) Uma das normas considerada na preparação do prédio do servidor é a ABNT NBR ISO/IEC 27.001. Dentre outras coisas, recomenda que a organização mantenha computadores desligados ou com a tela travada quando estes não estiverem em uso, além de não manter papéis com senhas ou

descrição de acesso a informações críticas em locais desprotegidos, denominada “política de mesa limpa e tela protegida”. Com base no que você estudou, a adoção desse tipo de política objetiva o controle de:

- a) () Gestão da continuidade do negócio.
- b) () Gestão de incidentes de segurança da informação.
- c) () Segurança de recursos humanos.
- d) (X) Acessos.

4 (CESPE 2016) Durante a preparação do prédio que hospeda o servidor do sistema da Secretaria da Saúde, foram levadas em consideração as principais normas de segurança lógica, física e ambiental. Para isto, várias medidas protetivas foram utilizadas. Correspondem a itens capazes de oferecer controle ou proteção no âmbito da segurança física preventiva.

- a) () As chaves públicas criptográficas.
- b) (X) Os dispositivos de autenticação biométrica.
- c) () Os sistemas de autenticação por senhas single sign-on.
- d) () Os certificados digitais.

5 (FCC 2018 – Adaptado) Depois de ataques sofridos, buscando definir a estrutura, as diretrizes e as obrigações referentes à segurança da informação para a solução da Secretaria da Saúde, foi definido uma política de segurança. Considere os seguintes controles da PS:

- I- Controlar o acesso de pessoas às áreas em que se encontram os servidores computacionais.
- II- Bloquear acesso dos funcionários para sites inseguros da internet.
- III- Instalar firewall para controlar os acessos externos para a rede local da empresa.
- IV- Controlar a temperatura das salas e corredores do prédio.

Os controles mencionados são, respectivamente, tipificados como de Segurança:

- a) **(X) Física, Lógica, Lógica e Ambiental.**
 - b) () Física, Lógica, Física e Ambiental.
 - c) () Lógica, Lógica, Ambiental e Lógica.
 - d) () Ambiental, Física, Lógica e Física.
- 6 (FGV 2010 – Adaptado) No que diz respeito à segurança do ambiente do prédio que fornece a infraestrutura para o servidor da Secretaria da Saúde, vários são os pontos que foram considerados, como a climatização do local, às instalações elétricas e fonte de energia alternativa. A respeito da umidade, o verdadeiro efeito que a alta umidade do ar pode causar em equipamentos elétricos é:
- a) () O superaquecimento dos equipamentos.
 - b) **(X) A corrosão dos equipamentos.**
 - c) () O excesso de eletricidade dinâmica e a eventual queima de equipamento.
 - d) () O aumento no consumo de energia para reduzir a temperatura.

UNIDADE 2

TÓPICO 1

- 1 Garantir a segurança em sistema operacional se torna um desafio para usuários e profissionais de tecnologia, dentre tais mecanismos existem os paradigmas de segurança da informação. Selecione a alternativa CORRETA que contenha os paradigmas.
- a) () Usuário garantidor de segurança; concentração e isolamento dos direitos privilegiados do computador; Liberação de Informações.
 - b) **(X) Usuário limitador de segurança; concentração e isolamento dos direitos privilegiados do computador; cifragem de informações.**

- c) () Computador limitador de segurança; coação dos direitos privilegiados do computador; cifragem de informações.
- d) () Chave restritiva de segurança; dispersão e inclusão dos direitos privilegiados do computador; decifragem de informações.

2 A segurança em sistemas operacionais remete ao emprego de várias estratégias. Sobre serviços de rede em sistemas operacionais assinale a alternativa CORRETA.

- a) () Neste quesito não é recomendável fornecer o número mínimo de serviços de rede necessários no computador servidor. Sendo assim, não há como garantir segurança a nível de rede em sistemas operacionais.
- b) () Neste quesito é recomendável fornecer o número máximo de serviços de rede necessários no computador servidor. A melhor saída é sempre fornecer o máximo de acesso possível.
- c) () Neste quesito não é recomendável fornecer o número mínimo de serviços de rede necessários no computador servidor. Para evitar riscos de segurança em sistema operacionais, o ideal é desabilitar tais recursos.
- d) (X) Neste quesito é recomendável fornecer o número mínimo de serviços de rede necessários no computador servidor. Utilizando, assim, apenas os serviços necessários para executar o aplicativo. Cada serviço de rede é um potencial ponto de entrada para ataques maliciosos.

3 Os sistemas operacionais são interfaces que permitem aos usuários interagir com o computador sem que seja necessário saber “falar a língua” dele. Sobre segurança em sistemas operacionais assinale a alternativa CORRETA.

- a) () Em sistemas operacionais Linux não há risco e nem vulnerabilidades.
- b) (X) Atualizar o sistema operacional é recomendado, pois previne contra falhas que foram corrigidas.
- c) () Para evitar riscos de segurança em sistema operacionais, o

ideal é formatar o computador com frequência.

- d) () Para garantir segurança em sistemas operacionais o ideal é sempre utilizar sistema operacional MacOS.

4 O sistema operacional é o ambiente físico onde seu aplicativo é executado. Qualquer vulnerabilidade no sistema operacional pode comprometer a segurança do aplicativo. Selecione a alternativa CORRETA sobre boas práticas de segurança em sistemas operacionais.

a) (X) Não instalar softwares ditos “piratas” é uma boa prática que visa garantir a segurança em sistemas operacionais.

b) () Não atualizar o sistema operacional é recomendado, pois previne contra falhas que foram corrigidas.

c) () Para evitar riscos de segurança em sistema operacionais, o ideal é formatar o computador com frequência.

d) () Para garantir segurança em sistemas operacionais o ideal é sempre utilizar sistema operacional on-line.

5 O sistema operacional é o conjunto de programas que gerenciam recursos, processadores, armazenamento, dispositivos de entrada e saída e dados da máquina e seus periféricos. O firewall exerce um importante papel para auxiliar na segurança a nível de sistema operacional.

Sobre firewall, assinale a alternativa CORRETA:

a) () Os firewalls são os programas invasores, utilizados para roubar dados dos usuários.

b) () Os firewalls são os programas antivírus.

c) (X) Os firewalls trabalham usando regras de segurança, fazendo com que pacotes de dados que estejam dentro das regras sejam aprovados, enquanto todos os outros nunca chegam ao destino.

d) () Os firewalls são os usuários na internet que trabalham para garantir a segurança dos dados.

TÓPICO 2

1 Analise as seguintes afirmativas referentes aos cuidados a serem tomados contra códigos maliciosos.

- I- O antivírus deve ser mantido sempre atualizado, com a versão mais recente e com todas as atualizações existentes aplicadas.
- II- O antivírus deve ser configurado para verificar automaticamente os discos rígidos e as unidades removíveis (como pen drives, CDs, DVDs e discos externos).
- III- O antivírus deve ser configurado para verificar toda e qualquer extensão de arquivo.

Estão CORRETAS as afirmativas:

- a) () I e II, apenas.
- b) () I e III, apenas.
- c) () II e III, apenas.
- d) (X) I, II e III.

2 (FCC - TRT, 2018) Considere o texto a seguir:

“Um grupo de especialistas em segurança encontrou um novo tipo de malware, que está se espalhando massivamente por meio do Facebook Messenger. Trata-se do Digmine, um malware que usa sistemas infectados para extrair a criptomoeda Monero. Esse malware é enviado às vítimas como um link para um arquivo de vídeo, quando na verdade é um script executável que afeta as versões desktop e web do Facebook Messenger, usando o navegador Google Chrome para minerar a moeda Monero no computador” (Adaptado de: <https://guiadobitcoin.com.br/>).

Esse tipo de malware, que parece ser uma coisa (vídeo), mas na realidade é outra (script de mineração), é categorizado como:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes?migalha=true&disciplina=46&prova=57055&modo=1>>. Acesso em: 2 ago. 2019.

- a) **(X) trojan.**
- b) () backdoor.
- c) () adware.
- d) () rootkit.

3 Quando abordamos segurança da informação a nível de software é comum tratar do tema trojan. Sobre o trojan, assinale a alternativa CORRETA.

- a) () Os Trojans são danosos, ou seja, causam algum dano ao sistema. Estes danos geralmente são a remoção ou alteração de arquivos importantes do sistema, mas existem trojans mais zombeteiros que trocam ícones, transformam pastas em atalhos, entre outras brincadeiras de mau tom.
- b) () Trojans é um software que o próprio usuário instala em sua máquina com o objetivo de monitorar a atividade de outros usuários. Tem se tornado uma prática comum em empresas com a finalidade de monitorar os funcionários
- c) () Trojans não são exatamente um programa e se não fosse uma técnica maliciosa poderíamos dizer se tratar de um conjunto de boas práticas, mas são um conjunto de práticas maliciosas que garantem que a presença de um invasor não seja notada em um dispositivo.
- d) **(X) Trojans são programas de computadores denominados cavalos de Tróia, que seguem a ideia da história real. São programas de computador que realizam a função para a qual foram designados e mais alguma função maliciosa.**

4 Em um ambiente operacional existem diversos softwares. Dentre esses softwares, existe o vírus. Sobre o vírus selecione a alternativa CORRETA.

- a) **(X) Os vírus são danosos, ou seja, causam algum dano ao sistema. Estes danos geralmente são a remoção ou alteração de arquivos importantes do sistema, mas existem vírus mais zombeteiros que trocam ícones, transformam pastas em atalhos, entre outras brincadeiras de mau tom.**

- b) () Vírus é um software que o próprio usuário instala em sua máquina com o objetivo de monitorar a atividade de outros usuários. Tem se tornado uma prática comum em empresas com a finalidade de monitorar os funcionários.
 - c) () Vírus não são exatamente um programa e se não fosse uma técnica maliciosa poderíamos dizer se tratar de um conjunto de boas práticas, mas são um conjunto de práticas maliciosas que garantem que a presença de um invasor não seja notada em um dispositivo.
 - d) () Vírus são programas de computadores denominados cavalos de Tróia, que seguem a ideia da história real. São programas de computador que realizam a função para a qual foram designados e mais alguma função maliciosa.
- 

TÓPICO 3

1 Os protocolos WEP, WPA e WPA2 podem ser utilizados na segurança de redes sem fio. Analise as proposições a seguir e marque a assertiva CORRETA.

- a) () A sigla WEP significa *Wireless Equivalent Privacy*.
- b) () O protocolo WEP é mais seguro que o protocolo WPA.
- c) (X) **WPA-Personal (ou WPA-PSK) foi projetado para ambientes pequenos e não requer um servidor para autenticação (por exemplo, RADIUS).**
- d) () O protocolo WPA não pode ser utilizado com o protocolo 802.1X.

2 Vivemos em uma era de avanços tecnológicos, se fala de Big Data, Internet das Coisas, Indústria 4.0, entre outros. Sobre segurança da informação e novas tecnologias selecione a alternativa CORRETA.

- a) () Como tais tecnologias não dependem de redes de computadores, não há preocupação com segurança.

- b) () A preocupação com segurança deve ser ampliada, para um mundo de coisas conectadas, uma invasão pode significar o controle total de dispositivos pelo invasor.
- c) (X) **Deve-se desconectar os dispositivos da rede para poder garantir segurança total.**
- d) () Deve-se sempre utilizar protocolo WPA.
- 3 A disponibilização de internet em locais públicos tem sido cada vez mais comum no cotidiano dos brasileiros. Todavia, a maioria dos utilizadores parecem esquecer das partes negativas que esta facilidade traz. Sobre a utilização deste tipo de rede, selecione a alternativa CORRETA.
- a) () A segurança é sempre garantida pelo proprietário.
- b) () Sempre é melhor se conectar quando a rede for aberta (não pedir autenticação).
- c) (X) **Nesse tipo de rede, o atacante pode estar monitorando a rede à espera de transações bancárias ou de log in em redes sociais.**
- d) () Deve-se sempre confiar em redes que utilizam as informações de log in e senha.
- 4 Para garantir melhor segurança em redes sem fio são utilizadas chaves de criptografia. A escolha de uma opção errada, e você terá uma rede mais lenta e menos segura. Apesar dos nomes estranhos e das possibilidades de problemas, essa configuração é importante e deve ser escolhida com calma, e claro, com algum conhecimento das tecnologias envolvidas. Selecione a alternativa CORRETA que contenha os principais tipos de criptografia.
- a) (X) **WEP, WPA, WPA2.**
- b) () SQL, DBA, DB2.
- c) () Rj45, WPA, WPA2.
- d) () WEB, DB2, WWW.

UNIDADE 3**TÓPICO 1**

- 1 (DATAPREV, 2014 – Adaptado) Quando se trata de segurança da informação, devemos sempre nos preocupar com normas e procedimentos que a empresa vai seguir para suas atividades, a fim de proteger sua informação e a de seu cliente, haja que a informação é o bem mais precioso que se tem atualmente. Devemos levar em conta que muitas vezes lidamos com informações do cliente ou mesmo informações críticas da nossa empresa, que devem ter sua confidencialidade e integridade mantidas, e as normas agregam procedimentos que visam a essa segurança (embora seguir as normas não seja garantia total de segurança).

Considerando essa preocupação, a ISO criou a série 27000, com normas específicas de segurança, que são as mais usadas pelo mercado. A série ISO 27000 é composta por várias normas, uma das quais apresenta um conjunto completo de controles que auxiliam aplicação do Sistema de Gestão da Segurança da Informação. Identifique, a seguir, qual alternativa contém essa norma.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/d61e85e4-fb>>. Acesso em: 4 ago. 2020.

- a) () ISO 27001.
- b) (X) ISO 27002.
- c) () ISO 27003.
- d) () ISO 27004.

- 2 (TCM-GO, 2012 – Adaptado) A norma ISO27001 foi preparada para prover um modelo para estabelecer, implementar, operar, monitorar, revisar, manter e melhorar um Sistema de Gestão de Segurança da Informação (SGSI). Com relação ao monitoramento, a organização deve conduzir auditorias internas no SGSI a intervalos planejados para determinar se os objetivos de controle, controles, processos e procedimentos de seu SGSI:

- I- Obedecem aos requisitos desta Norma e à legislação pertinente ou regulamentos.
- II- São executados conforme esperado.
- III- Obedecem aos requisitos de segurança da informação identificadas.
- IV- São efetivamente implementados e mantidos.

Assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/d61e85e4-fb>>. Acesso em: 4 ago. 2020.

a) (X) As afirmativas I, II, III e IV estão corretas.

b) () As afirmativas I e IV estão corretas.

c) () As afirmativas I, II e III estão corretas.

d) () As afirmativas II, III e IV estão corretas.

3 (TCM-GO, 2012 – Adaptado) De acordo com a norma ISO27002, em Segurança de Recursos Humanos, antes do processo de contratação, convém que no processo de seleção sejam observados os seguintes itens:

- I- Uma verificação das informações do curriculum vitae do candidato.
- II- Confirmação das qualificações acadêmicas e profissionais.
- III- Disponibilidade de referências de caráter satisfatórias, por exemplo uma profissional e uma pessoal.
- IV- Verificações financeiras ou de antecedentes criminais.

Assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/8171c20c-b1>>. Acesso em: 4 ago. 2020.

a) (X) As afirmativas I, II, III e IV estão corretas.

b) () As afirmativas I e IV estão corretas.

c) () As afirmativas I, II e III estão corretas.

d) () As afirmativas II e IV estão corretas.

4 (TJ-PA, 2014 – Adaptado)

O tempo dirá se o Marco Civil da internet é bom ou ruim

Foi aprovado o Marco Civil da internet: aquilo a que chamam de “Constituição da internet” e que será capaz de afetar diretamente a vida de milhões de usuários que já não usam mais a internet apenas para se divertir, mas para trabalhar.

O Marco Civil garantirá a neutralidade da rede, segundo a qual todo o conteúdo que trafega pela internet será tratado de forma igual. As empresas de telecomunicações que fornecem acesso poderão continuar vendendo velocidades diferentes. Mas terão de oferecer a conexão contratada independentemente do conteúdo acessado pelo internauta e não poderão vender pacotes restritos.

O Marco Civil garante a inviolabilidade e o sigilo das comunicações. O conteúdo poderá ser acessado apenas mediante ordem judicial. Na prática, as conversas via Skype e as mensagens salvas na conta de e-mail não poderão ser violadas, a menos que o Judiciário determine.

Excluiu-se do texto aprovado um artigo que obrigava empresas estrangeiras a instalar no Brasil seus datacenters (centros de dados para armazenamento de informações). Por outro lado, o projeto aprovado reforçou dispositivo que determina o cumprimento das leis brasileiras por parte de companhias internacionais, mesmo que não estejam instaladas no Brasil.

Ressalte-se ainda que a exclusão de conteúdo só poderá ser ordenada pela Justiça. Assim, não ficará mais a cargo dos provedores a decisão de manter ou remover informações e notícias polêmicas. Portanto, o usuário que se sentir ofendido por algum conteúdo no ambiente virtual terá de procurar a Justiça, e não as empresas que disponibilizam os dados.

Este é o Marco Civil que temos. Se é o que pretendíamos ter, o tempo vai mostrar. Mas, sem dúvida, será menos pior do que não termos marco civil nenhum.

(O Liberal, Editorial de 24.04.2014. Adaptado)

De acordo com o texto, o Marco Civil da internet:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/c4ac52ab-24>>. Acesso em: 4 ago. 2020.

- a) (X) **Dispõe sobre as relações entre empresas de telecomunicações e usuários da rede e defende o caráter inviolável dos conteúdos circulantes no ambiente virtual.**
 - b) () **Garante que órgãos do governo tenham livre acesso a conversas via Skype e a mensagens salvas na conta de e-mail dos usuários brasileiros.**
 - c) () **Determina quais conteúdos podem ser considerados neutros ou polêmicos, orientando os usuários quanto aos sites moralmente idôneos.**
 - d) () **Exige que empresas estrangeiras instalem centros de armazenamento de dados e informações no Brasil se quiserem oferecer seus serviços a usuários brasileiros.**
- 5 (CRN 3ª Região, 2019 – Adaptado) **A Lei nº 13.709/2018 (Lei Geral de Proteção de Dados) incide quanto ao cadastro de usuários e clientes, alterando a maneira como as organizações devem tratar dados pessoais, com vistas a proteger os direitos fundamentais de liberdade e de privacidade e a respeitar o livre desenvolvimento da personalidade, a dignidade e o exercício da cidadania. Considerando o disposto na referida lei, assinale a alternativa CORRETA.**

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/7019ffd7-7d>>. Acesso em: 4 ago. 2020.

- a) () **Essa lei aplica-se exclusivamente a dados coletados por meio digital.**
- b) (X) **O tratamento de dados pessoais, bem como o compartilhamento desses dados, somente é permitido mediante consentimento do titular, salvo casos de exceção previstos na lei.**
- c) () **Dados pessoais de crianças podem ser coletados sem consentimento prévio e armazenados para fins de contato com os pais ou o responsável legal.**
- d) () **O consentimento do tratamento dos dados deve ser fornecido pelo titular antecipadamente à coleta dos dados e presume concordância com o compartilhamento dos respectivos dados pessoais com entidades parceiras por tempo indeterminado.**

6 (TJ-PA, 2020 – Adaptado) De acordo com a Lei nº 13.709/2018 (Lei Geral de Proteção de Dados Pessoais), as atividades de tratamento de dados pessoais devem observar a boa-fé e o princípio:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/0e34286c-44>>. Acesso em: 4 ago. 2020.

- a) () De dado pessoal, segundo o qual a informação é relacionada à pessoa natural identificada ou identificável.
- b) () Da anonimização, com a utilização de meios técnicos razoáveis e disponíveis no momento do tratamento, por meio dos quais um dado perde a possibilidade de associação, direta ou indireta, a um indivíduo.
- c) (X) **Da prevenção, com a adoção de medidas para prevenir a ocorrência de danos em virtude do tratamento de dados pessoais.**
- d) () Da eliminação, que é a exclusão de dado ou de conjunto de dados armazenados em banco de dados, independentemente do procedimento empregado.

TÓPICO 2

1 (UFG, 2010 – Adaptado) Existem duas filosofias por trás de qualquer política de segurança: a proibitiva (tudo que não é expressamente permitido é proibido) e a permissiva (tudo que não é proibido é permitido). Portanto, uma característica da política de segurança válida é a:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/eb5199a2-87>>. Acesso em: 4 ago. 2020.

- a) () utilização, visto que o sistema deve ser utilizado de propósito geral com os objetivos determinados.
- b) () disponibilidade, esta característica deve estar disponível para quando o usuário necessitar utilizar os dados e solicitar ao administrador que mude as permissões de acesso.

- c) () integridade, pois o sistema deve estar sempre íntegro e em condições de ser usado, porém a senha tem de ser validada pelo gerente.
- d) (X) **autenticidade, já que o sistema deve ter condições de verificar a identidade do usuário, e este deve ter condições de analisar a identidade do sistema.**

2 (SUSEP, 2010 – Adaptado) Atualmente, a informação é um importante ativo para praticamente todo o tipo de organização. A segurança desse ativo faz-se necessária, seja por questão de conformidade com leis e contratos, seja para assegurar a continuidade do negócio. Por política de segurança entende-se:

FONTE: <<https://www.questao certa.com.br/questao/MjQ2NDc5>>. Acesso em: 4 ago. 2020.

- a) () política planejada, válida para os setores críticos da organização, com regras o mais claro e simples possível, e estrutura gerencial de fiscalização dessa política, claramente sustentada pela alta hierarquia da área de informática.
- b) (X) **política elaborada, implantada e em contínuo processo de revisão, válida para toda a organização, com regras o mais claro e simples possível, e estrutura gerencial e material de suporte a essa política, claramente sustentada pela alta hierarquia.**
- c) () política e diretrizes de implantação, em contínuo processo de desenvolvimento, fiscalizada por toda a organização, com regras criptografadas e estrutura matricial e material de priorização dessa política, claramente sustentada pela alta hierarquia.
- d) () política elaborada, implantada e imune a revisões, válida para toda a organização, com estrutura gerencial de regras de formalização individualizada dessa política nas unidades organizacionais, claramente sustentada pelos gestores do nível operacional.

3 (CGU, 2004 – Adaptado) A política de segurança é um conjunto de diretrizes, normas, procedimentos e instruções de trabalho que estabelecem os critérios de segurança para serem adotados no nível local ou a institucional, visando o estabelecimento, a padronização e a normalização da segurança tanto no âmbito humano quanto tecnológico. Acerca da política de segurança da informação, analise as seguintes afirmações relativas a aspectos que devem ser considerados.

- I- Uma boa política de segurança independe do treinamento aplicado aos funcionários.
- II- A criptografia pode garantir a integridade dos dados e proteger informações sigilosas enviadas através de linhas inseguras.
- III- Controle de acesso é aplicado após a implementação da política de segurança para garantir que todos os itens da política estão sendo cumpridos.
- IV- A autenticação é como os usuários informam à infraestrutura de rede quem são eles.

Assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/d904fd80-cb>>. Acesso em: 4 ago. 2020.

- a) () As afirmativas I e II estão corretas.
- b) () As afirmativas III e IV estão corretas.
- c) () As afirmativas I e III estão corretas.
- d) (X) As afirmativas II e IV estão corretas.

4 (VUNESP, 2018 – Adaptado) Considerando a segurança da informação em uma organização, dois importantes documentos a serem escritos e aplicados são a política de segurança da informação e o plano de continuidade de negócios. A respeito destes temas, é CORRETO afirmar que:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/9b00ded1-ea>>. Acesso em: 4 ago. 2020.

- a) () A política de segurança da informação não inclui a forma de controle de acesso a seus equipamentos computacionais.
- b) () O propósito principal do plano de continuidade é a determinação dos horários de trabalho, sob condições normais, dos funcionários da empresa.
- c) (X) **Um dos recursos necessários para que o plano de continuidade possa ser ativado inclui as pessoas ou recursos humanos.**
- d) () Para a ativação do plano de continuidade, não é necessária a utilização de recursos tecnológicos.

5 (CCV-UFC, 2013 – Adaptado) Durante uma inspeção de rotina foi identificado que uma empresa não possui um plano de continuidade para um determinado serviço de TI. Escolha, entre as opções a seguir, qual seria um motivo válido para a inexistência do plano de continuidade para o serviço.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/b090fb19-b6>>. Acesso em: 4 ago. 2020.

- a) () A área de TI da empresa não possui competência para executar essa atividade.
- b) (X) **Uma decisão foi tomada com base em uma avaliação dos impactos para o negócio.**
- c) () Decidiu-se na área de TI da empresa que os riscos de problemas para esse serviço são reduzidos.
- d) () O service desk estaria preparado para resolver qualquer tipo de problema ou incidente sem o plano de continuidade para o serviço.

6 (DPE-RS, 2017 – Adaptado) O Plano de Continuidade dos Negócios é um roteiro de operações contínuas para quando as operações normais dos negócios são interrompidas por condições adversas. A respeito do Plano de Continuidade dos Negócios, assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/70b16806-9e>>. Acesso em: 4 ago. 2020.

- a) (X) Deve incluir, dentre outras coisas, a definição dos cenários de impacto e a análise de ameaças e riscos.
 - b) () Deve ser de responsabilidade do departamento de TI, que é considerado o único com competências necessárias para conter possíveis desastres.
 - c) () Deve possuir ações genéricas para conter qualquer tipo de desastre, evitando assim que tenha que ser revisado periodicamente.
 - d) () Deve ser executado integralmente em resposta a incidentes que causem interrupção total ou parcial das operações normais de negócios.
- 

TÓPICO 3

1 (ESAF, 2008 – Adaptado) Segundo a ABNT NBR ISO/IEC 27002, segurança está fundamentada sobre três propriedades que devem ser mantidas: confidencialidade, integridade e disponibilidade das informações. Analise as afirmações relacionadas à segurança da informação e os objetivos do controle de acesso.

- I- A disponibilidade é uma forma de controle de acesso que permite identificar os usuários legítimos da informação para que lhes possa ser liberado o acesso, quando solicitado.
- II- A confidencialidade é uma forma de controle de acesso que evita que pessoas não autorizadas tenham acesso à informação para criá-la, destruí-la ou alterá-la indevidamente.
- III- A integridade é uma forma de controle de acesso que evita o acesso de pessoas não autorizadas a informações confidenciais, salvaguardando segredos de negócios e protegendo a privacidade de dados pessoais.

Assinale a alternativa CORRETA:

FONTE: <<https://www.tecnolegis.com/provas/comentarios/47825#:~:text=A%20integridade%20C3%A9%20uma%20forma,a%20privacidade%20de%20dados%20pessoais.>>. Acesso em: 4 ago. 2020.

- a) () As afirmativas I e II estão corretas.
- b) () As afirmativas I e III estão corretas.
- c) () As afirmativas II e III estão corretas.
- d) (X) A afirmativa I está correta.

2 (CETESB, 2009 – Adaptado) O uso da VPN (Rede Privada Virtual) é uma necessidade nos dias de hoje para aumentar a segurança na comunicação de dados pela rede de computadores. A respeito do principal objetivo de uma VPN visa permitir, assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/cdfb62de-9e>>. Acesso em: 4 ago. 2020.

- a) () Utilizem IPs virtuais em uma rede local.
- b) () Realizem conexões remotas e seguras para redes corporativas.
- c) () Testem equipamentos e redes em ambiente de simulação.
- d) (X) Virtualizem os equipamentos utilizados na rede local.

3 (TRE-MS 2012 – Adaptado) Com base na norma NBR ISO/IEC 27.001:2013, o fato de uma organização manter computadores desligados ou com a tela travada quando estes não estiverem em uso e não manter papéis com senhas ou descrição de acesso a informações críticas em locais desprotegidos caracteriza a denominada “política de mesa limpa e tela protegida”. A adoção dessa política tem um objetivo. Assinale a alternativa que corretamente apresenta este objetivo.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/b9fc8db7-5b>>. Acesso em: 4 ago. 2020.

- a) () Controle de gestão da continuidade do negócio.
- b) () Controle de gestão de incidentes de segurança da informação.
- c) () Controle de segurança de recursos humanos.
- d) (X) Controle de acessos.

4 (TJ-PA, 2020 – Adaptado) Um dos desafios atuais da segurança da informação é o crescente uso de BYOD (bring your own device, ou, em português, traga seu próprio dispositivo) nas instituições. Notebooks, tablets e principalmente smartphones estão invadindo as redes institucionais. Nesse contexto, são necessárias políticas, procedimentos e tecnologias especializadas acerca do tema. Com base na NBR ISO/IEC nº 27002, em uma política de dispositivos móveis, é CORRETO:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/0e6a83dc-44>>. Acesso em: 4 ago. 2020.

- a) () Validar informações de entrada no sistema somente quando todos os dados de entrada estiverem completos e íntegros, em conformidade com as boas práticas.
- b) (X) **Separar o uso do dispositivo para negócio e para fins pessoais, incluindo os softwares para apoiar essa separação e proteger os dados do negócio em um dispositivo privado.**
- c) () Avaliar regularmente a referida política quanto a sua capacidade de atender ao crescimento do negócio e às interações com outras utilidades.
- d) () Segregar as funções de controle de acesso como, por exemplo, pedido de acesso, autorização de acesso e administração de acesso.

5 (TCE-RO, 2019 – Adaptado) Uma organização considera a possibilidade de implantar a modalidade de trabalho remoto, incluindo acesso remoto à intranet por meio de smartphones e computadores. Nessa hipótese, de acordo com a norma NBR ISO/IEC nº 27002:2013, recomenda-se:

- I- Manter no campo de observação, os dispositivos móveis com acesso remoto autorizado que contenham informações importantes, sensíveis ou críticas para o negócio.
- II- Usar criptografia nos dispositivos móveis e de acesso remoto, para prevenir o acesso não autorizado ou a divulgação de informações armazenadas e processadas nesses dispositivos.
- III- Fornecer acesso virtual às estações de trabalhos dos usuários com o objetivo de mitigar tentativas de ataques que venham a explorar falhas desse recurso.

IV- Acessar equipamentos de propriedade particular autorizados para acesso remoto, com o objetivo de verificar a segurança da máquina.

Assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/9d8b1fe7-11>>. Acesso em: 4 ago. 2020.

- a) () As afirmativas I, II e III estão corretas.
- b) () As afirmativas I e IV estão corretas.
- c) (X) **As afirmativas I, II e IV estão corretas.**
- d) () As afirmativas II, III e IV estão corretas.

TÓPICO 4

1 (TRE-AM, 2010 – Adaptado) Com relação à implementação de segurança em redes de computadores, considere:

- I- No contexto empresarial, a segurança de redes é obtida através da utilização do uso apropriado de equipamentos e políticas de segurança que administrem o uso desses recursos em relação à segurança de redes e controle de acesso que assegurem a integridade dos serviços executados nos sistemas operacionais.
- II- O entendimento apropriado sobre o risco permite aos administradores a habilidade de avaliar a relação custo-benefício e decidir sobre implementar controles para a correção de vulnerabilidades ou arcar com as consequências de uma ameaça potencial de invasão.
- III- Em ambientes de rede de computadores o gerenciamento de riscos deve ocorrer através de auditorias periódicas nos principais equipamentos de conectividade e sistemas de proteção de rede existentes. O processo de análise de riscos deve cobrir o maior número possível de ativos de tecnologia, tais como: roteadores de borda, roteadores de acesso remoto, access points, sistemas de proxy, sistemas antivírus e firewalls.

IV- O custo para implementar controles que evitem vulnerabilidades, tais como: servidores de e-mails inadequadamente configurados, implementações de segurança específicas para alguns ativos de TI e substituição de servidores open relay é relativamente maior que suas consequências, invalidando, dessa forma, a política de segurança.

Assinale a alternativa CORRETA:

FONTE: <<https://olhonavaga.com.br/questoes/questoes?id=388615&tc=1>>. Acesso em: 4 ago. 2020.

- a) () As afirmativas I e II estão corretas.
- b) () As afirmativas I e IV estão corretas.
- c) (X) As afirmativas I, II e III estão corretas.
- d) () As afirmativas II, III e IV estão corretas.

2 (TRE-MS, 2012 – Adaptado) Para proteger uma área que abriga recursos de processamento da informação, um órgão público, com base na norma ABNT NBR ISO/IEC 27001, instalou uma porta com controle de acesso por cartão, de modo a que somente os colaboradores previamente autorizados possam acessar esse ambiente. Nessa situação hipotética, de acordo com a referida norma da ABNT, assinale a medida adotada pelo órgão público a que se associa.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/b89d20c8-5b>>. Acesso em: 4 ago. 2020.

- a) () À validação de dados de saída.
- b) () Ao controle de vulnerabilidades.
- c) () Ao controle contra códigos móveis.
- d) (X) Ao controle de perímetro de segurança física.

3 (CGU, 2004 – Adaptado) Considere um sistema no qual existe um conjunto de informações disponível para um determinado grupo de usuários denominados "auditores". Após várias consultas com respostas corretas, em um determinado momento, um usuário pertencente ao grupo "auditores" acessa o sistema em busca de

uma informação e recebe, como resposta a sua consulta, uma informação completamente diferente da desejada. Nesse caso, houve uma falha na segurança da informação para este sistema. Assinale a alternativa que apresenta a propriedade relacionada à falha.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/ba82933c-9a>>. Acesso em: 4 ago. 2020.

- a) () Confidencialidade.
- b) (X) Integridade.
- c) () Auditoria.
- d) () Privacidade.

4 (CGU, 2006 – Adaptado) De acordo com a norma ABNT NBR ISO/IEC 27001 de 2013, a organização deve conduzir auditorias do SGSI. Analise as seguintes afirmações relacionadas a Auditoria de Sistemas.

- I- O auditor de Tecnologia da Informação deve ser ligado diretamente à área sob auditoria, devendo ser, preferencialmente, um funcionário ou ter um cargo nessa área.
- II- O colaborador a ser auditado deve planejar as tarefas de auditoria para direcionar os objetivos da auditoria e seguir os padrões profissionais aplicáveis.
- III- O auditor de Tecnologia da Informação deve requisitar e avaliar informações apropriadas sobre pontos, conclusões e recomendações anteriores e relevantes para determinar se ações apropriadas foram implementadas em tempo hábil.
- IV- A auditoria realizada em Tecnologia da Informação engloba a verificação de operações, processos, sistemas e responsabilidades.

Assinale a alternativa CORRETA:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/5583467b-f6>>. Acesso em: 4 ago. 2020.

- a) () As afirmativas I e II estão corretas.
- b) () As afirmativas II e III estão corretas.
- c) (X) As afirmativas III e IV estão corretas.
- d) () As afirmativas I e IV estão corretas.

5 (DPE-RJ, 2019 – Adaptado) De acordo com a norma ABNT NBR ISO/IEC 27001:2013, uma organização deve programar auditorias internas a fim de verificar a aderência da conformidade do sistema de gestão da segurança da informação aos seus requisitos e à legislação vigente. Sobre a realização da auditoria interna, é correto afirmar que:

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/f6b927aa-65>>. Acesso em: 4 ago. 2020.

- a) () Os critérios de verificação devem ser sempre os mesmos, independentemente do escopo ou do processo da organização a ser auditado.
- b) () Os auditores não devem conhecer e considerar os resultados das auditorias anteriores para não influenciarem o trabalho de verificação.
- c) () Os auditores devem ser do próprio setor auditado a fim de possibilitar o aproveitamento de seu conhecimento acerca das atividades desenvolvidas.
- d) (X) Os resultados das auditorias devem ser de conhecimento da direção responsável pelo setor auditado.

6 (SEFAZ-SP, 2013 – Adaptado) A auditoria da segurança da informação avalia a política de segurança e os controles relacionados adotados em cada organização. Nesse contexto, muitas vezes, as organizações não se preocupam, ou até negligenciam, um aspecto básico da segurança que é a localização dos equipamentos que podem facilitar a intrusão. Na auditoria de segurança da informação, assinale a alternativa que apresenta o nome desse aspecto.

FONTE: <<https://www.qconcursos.com/questoes-de-concursos/questoes/6e45c0db-ee>>. Acesso em: 4 ago. 2020.

- a) () Controle de acesso lógico.
- b) (X) Controle de acesso físico.**
- c) () Controle de conteúdo.
- d) () Controle de entrada e saída de dados.



UNIASSELVI

Construa sua própria história.